Based on Commission filings, we estimate that approximately 872 broker-dealers,[1154] 132 transfer agents,[1155] 81 investment companies,[1156] and 579 registered investment advisers[1157] may be considered small entities.

D. Projected Reporting, Recordkeeping, and Other Compliance Requirements

The final amendments to Regulation S-P will require covered institutions to develop incident response programs for unauthorized access to or use of customer information, as well as imposing a customer notification obligation in instances where sensitive customer information was, or is reasonably likely to have been, accessed or used without authorization. The final amendments also would include new mandatory recordkeeping requirements and language conforming Regulation S-P's annual privacy notice delivery provisions to the terms of a statutory exception.

Under the final amendments, covered institutions would have to develop, implement, and maintain, within their written policies and procedures designed to comply with Regulation S-P, a program that is reasonably designed to detect, respond to, and recover from unauthorized access to or use of customer information, including customer notification procedures. Such policies and procedures will also need to require that covered institutions oversee, monitor, and conduct due diligence on service providers and ensure that service providers take appropriate measures to notify covered institutions of an applicable breach in security within 72 hours. Upon receipt of

---

1154 Estimate based on Q3 2023 FOCUS Report data, staff analysis and public filings. This 872 broker-dealers includes 89 funding portals.

1155 Estimate based on the number of transfer agents that reported a value of fewer than 1,000 for items 4(a) and 5(a) on Form TA-2 collected by the Commission as of September 30, 2023.

1156 Based on Commission staff approximation that approximately 41 open-end funds (including 10 exchange-traded funds), 23 closed-end funds, 3 UITs and 14 business development companies are small entities. This estimate is derived from an analysis of data obtained from Morningstar Direct and data reported to the Commission (*e.g.* N-PORT, N-CSR, 10-Q and 10-K) for the second quarter of 2023.

1157 Based on SEC-registered adviser responses to Items 5.F. and 12 of Form ADV as of October 5, 2023.

such notification, the covered institution must initiate its incident response program. As part of its incident response program, a covered institution may also enter into a written agreement with its service provider to have the service provider notify affected individuals on its behalf. However, the covered institution's obligation to ensure that affected individuals are notified in accordance with paragraph (a)(4) of the final amendments rests with the covered institution.

In addition, covered institutions will be required to make and maintain specified written records designed to evidence compliance with these requirements.[1158] Such records will be required to be maintained starting from when the record was made, or from when the covered institution terminated the use of the written policy or procedure, for the time periods stated in the amended recordkeeping regulations for each type of covered institution.

Some covered institutions, including covered institutions that are small entities, will incur increased costs involved in reviewing and revising their current safeguarding policies and procedures to comply with these obligations, including their cybersecurity policies and procedures. Initially, this will require covered institutions to develop as part of their written policies and procedures under the safeguards rule, a program reasonably designed to detect, respond to, and recover from any unauthorized access to or use of customer information, including customer notification procedures, in a manner that provides clarity for firm personnel. Further, in developing these policies and procedures, covered institutions will need to include policies and procedures requiring the covered institution to ensure its service providers take appropriate measures to protect against unauthorized access to or use of customer information, and notify the covered institution as soon as possible, but no later than 72 hours after becoming

---

[1158] With regard to funding portals, please see discussion as to their applicable recordkeeping obligations *supra* footnote 385 and accompanying discussion.

aware that a breach in security has occurred resulting in unauthorized access to a customer information system maintained by the service provider, and upon receipt of such notification, the covered institution must initiate its response program. However, as the Commission recognizes the number and varying characteristics (e.g., size, business, and sophistication) of covered institutions, these final amendments would help covered institutions to tailor these policies and procedures and related incident response program based on the individual facts and circumstances of the firm, and provide flexibility in addressing the general elements of the response program requirements based on the size and complexity of the covered institution and the nature and scope of its activities.

In addition, the Commission acknowledges that the final amendments will impose greater costs on those transfer agents that are registered with another appropriate regulatory agency, if they are not currently subject to Regulation S-P, as well as those transfer agents registered with the Commission who are not currently subject to the safeguards rule. Such costs will include the development and implementation of necessary policies and procedures, the ongoing costs of required recordkeeping and maintenance requirements, and, where necessary, the costs to comply with the customer notification requirements of the final amendments. Such costs will also include the same minimal costs for employee training or establishing clear procedures for consumer report information disposal that are imposed on all covered institutions. To the extent that such costs are being applied to a transfer agent for the first time as a result of new obligations being imposed, the final amendments would incur higher present costs on those transfer agents than those covered institutions that are already subject to the safeguards rule and the disposal rule.

To comply with these amendments on an ongoing basis, covered institutions will need to respond appropriately to incidents that entail the unauthorized access to or use of customer information. This will entail carrying out the established response program procedures to (i) assess the nature and scope of any incident involving unauthorized access to or use of customer information and identify the customer information systems and types of customer information that may have been accessed or used without authorization; (ii) take appropriate steps to contain and control the incident to prevent further unauthorized access to or use of customer information; and (iii) notify each affected individual whose sensitive customer information was, or is reasonably likely to have been, accessed or used without authorization, unless the covered institution determines, after a reasonable investigation of the facts and circumstances of the incident of unauthorized access to or use of sensitive customer information, that the sensitive customer information has not been, and is not reasonably likely to be, used in a manner that would result in substantial harm or inconvenience.

Where the covered institution determines notice is required, the covered institution will need to provide a clear and conspicuous notice, or ensure that such notice is provided, to each affected individual whose sensitive customer information was, or is reasonably likely to have been, accessed or used without authorization. This notice must be provided as soon as reasonably practicable, but not later than 30 days, after the covered institution becomes aware that unauthorized access to or use of sensitive customer information has, or is reasonably likely to have, occurred, absent an applicable request from the Attorney General. This notice will need to be transmitted by a means designed to ensure that each affected individual can reasonably be expected to receive actual notice in writing. Further, the covered institution will need to satisfy

the specified content requirements of that notice,[1159] the preparation of which will incur some incremental additional costs on covered institutions.

Finally, covered institutions will also face costs in complying with the new recordkeeping requirements imposed by these amendments that are incrementally more than those costs covered institutions already incur from their existing regulatory recordkeeping obligations, in light of their already existing record retention systems. However, the record maintenance provisions align with those most frequently employed as to each covered institution subject to this rulemaking, partially in an effort to minimize these costs to firms.

Overall, incremental costs will be associated with the final amendments to Regulation S-P.[1160] Some proportion of large or small institutions would be likely to experience some increase in costs to comply with the amendments.

More specifically, we estimate that many covered institutions will incur one-time costs related to reviewing and revising their current safeguarding policies and procedures to comply

---

[1159] *See* final rule 248.30(a)(4)(iv). In particular, the covered institution would need to: (i) describe in general terms the incident and the type of sensitive customer information that was or is reasonably believed to have been accessed or used without authorization; (ii) include, if the information is reasonably possible to determine at the time the notice is provided, any of the following: the date of the incident, the estimated date of the incident, or the date range within which the incident occurred; (iii) include contact information sufficient to permit an affected individual to contact the covered institution to inquire about the incident, including the following: a telephone number (which should be a toll-free number if available), an email address or equivalent method or means, a postal address, and the name of a specific office to contact for further information and assistance; (iv) if the individual has an account with the covered institution, recommend that the customer review account statements and immediately report any suspicious activity to the covered institution; (v) explain what a fraud alert is and how an individual may place a fraud alert in the individual's credit reports to put the individual's creditors on notice that the individual may be a victim of fraud, including identity theft; (vi) recommend that the individual periodically obtain credit reports from each nationwide credit reporting company and that the individual have information relating to fraudulent transactions deleted; (vii) explain how the individual may obtain a credit report free of charge; and (viii) include information about the availability of online guidance from the FTC and usa.gov regarding steps an individual can take to protect against identity theft, a statement encouraging the individual to report any incidents of identity theft to the FTC, and include the FTC's website address where individuals may obtain government information about identity theft and report suspected incidents of identity theft.

[1160] Covered institutions are currently subject to similar recordkeeping requirements applicable to other required policies and procedures. Therefore, covered institutions will generally not need to invest in new recordkeeping staff, systems, or procedures to satisfy the new recordkeeping requirements.

with these obligations, including their cybersecurity policies and procedures. Additionally, some covered institutions, including transfer agents, may incur costs associated with establishing such policies and procedures as these amendments require if those covered institutions do not already have such policies and procedures. We also estimate that the ongoing, long-term costs associated with the final amendments could include costs of responding appropriately to incidents that entail the unauthorized access to or use of customer information.

E. Agency Action to Minimize Effect on Small Entities

The RFA directs us to consider alternatives that would accomplish our stated objectives, while minimizing any significant adverse impact on small entities. Accordingly, we considered the following alternatives:

1. Establishing different compliance or reporting standards that take into account the resources available to small entities;
2. The clarification, consolidation, or simplification of the reporting and compliance requirements under the rule for small entities;
3. Use of performance rather than design standards; and
4. Exempting small entities from coverage of the rule, or any part of the rule.

With regard to the first alternative, the final amendments to Regulation S-P that will continue to permit institutions substantial flexibility to design safeguarding policies and procedures appropriate for their size and complexity, the nature and scope of their activities, and the sensitivity of the personal information at issue. However, it is necessary to require that covered institutions, regardless of their size, adopt a response program for incidents of unauthorized access to or use of customer information, which will include customer notification

procedures.[1161] The amendments to Regulation S-P arise from our concern with the increasing number of information security breaches that have come to light in recent years, particularly those involving institutions regulated by the Commission. Establishing different compliance or reporting requirements for small entities could lead to less favorable protections for these entities' customers and compromise the effectiveness of the amendments. However, we are providing smaller covered institutions a longer compliance period to establish and implement processes to comply with the final amendments.

With regard to the second alternative, the final amendments will, by their operation, simplify reporting and compliance requirements for small entities. Small covered institutions are likely to maintain personal information on fewer individuals than large covered institutions, and they are likely to have relatively simple personal information systems. The amendments will not prescribe specific steps a covered institution must take in response to a data breach, but instead would give the institution flexibility to tailor its policies and procedures to its individual facts and circumstances. The amendments therefore are intended to give covered institutions the flexibility to address the general elements in the response program based on the size and complexity of the institution and the nature and scope of its activities. Accordingly, the requirements of the amendments already will be simplified for small entities. In addition, the requirements of the amendments could not be further simplified, or clarified or consolidated, without compromising the investor protection objectives the amendments are designed to achieve.

With regard to the third alternative, the final amendments are design based. Rather than specifying the types of policies and procedures that an institution would be required to include in

---

[1161] *See* final rule 248.30(a)(3).

its response program, the amendments will require a response program that is reasonably designed to detect, respond to, and recover from both unauthorized access to and unauthorized use of customer information. With respect to the specific requirements regarding notifications in the event of a data breach, institutions provide only the information that seems most relevant for an affected customer to know in order to assess adequately the potential damage that could result from the breach and to develop an appropriate response.

Finally, with regard to alternative four, an exemption for small entities would not be appropriate. Small entities are as vulnerable as large ones to the types of data security breach incidents we are trying to address. In this regard, the specific elements the final amendments must be considered and incorporated into the policies and procedures of all covered institutions, regardless of their size, to mitigate the potential for fraud or other substantial harm or inconvenience to investors. Exempting small entities from coverage of the amendments or any part of the amendments could compromise the effectiveness of the amendments and harm investors by lowering standards for safeguarding investor information maintained by small covered institutions. Excluding small entities from requirements that would be applicable to larger covered institutions also could create competitive disparities between large and small entities, for example by undermining investor confidence in the security of information maintained by small covered institutions.

STATUTORY AUTHORITY

The Commission is amending Regulation S-P pursuant to authority set forth in sections 17, 17A, 23, and 36 of the Exchange Act [15 U.S.C. 78q, 78q-1, 78w, and 78mm], sections 31 and 38 of the Investment Company Act [15 U.S.C. 80a-30 and 80a-37], sections 204, 204A, and 211 of the Investment Advisers Act [15 U.S.C. 80b-4, 80b-4a, and 80b-11], section 628(a) of the

FCRA [15 U.S.C. 1681w(a)], and sections 501, 504, 505, and 525 of the GLBA [15 U.S.C. 6801, 6804, 6805, and 6825].

List of Subjects

17 CFR Parts 240, 270, and 275

Reporting and recordkeeping requirements; Securities.

17 CFR Part 248

Brokers, Consumer protection, Dealers, Investment advisers, Investment companies, Privacy, Reporting and recordkeeping requirements, Securities, Transfer agents.

TEXT OF RULE AMENDMENTS

For the reasons set out in the preamble, title 17, chapter II of the Code of Federal Regulations is amended as follows:

PART 240—GENERAL RULES AND REGULATIONS, SECURITIES EXCHANGE ACT OF 1934

1. The authority citation for part 240 and the sectional authority for § 240.17Ad-7 are revised to read, as follows:

Authority: 15 U.S.C. 77c, 77d, 77g, 77j, 77s, 77z-2, 77z-3, 77eee, 77ggg, 77nnn, 77sss, 77ttt, 78c, 78c-3, 78c-5, 78d, 78e, 78f, 78g, 78i, 78j, 78j-1, 78j-4, 78k, 78k-1, 78*l*, 78m, 78n, 78n-1, 78*o*, 78*o*-4, 78*o*-10, 78p, 78q, 78q-1, 78s, 78u-5, 78w, 78x, 78dd, 78*ll*, 78mm, 80a-20, 80a-23, 80a-29, 80a-37, 80b-3, 80b-4, 80b-11, 1681w(a)(1), 6801-6809, 6825, 7201 *et seq.,* and 8302; 7 U.S.C. 2(c)(2)(E); 12 U.S.C. 5221(e)(3); 18 U.S.C. 1350; Pub. L. 111-203, 939A, 124 Stat. 1376 (2010); and Pub. L. 112-106, sec. 503 and 602, 126 Stat. 326 (2012), unless otherwise noted.

* * * * *

Section 240.17a-14 is also issued under Public Law 111-203, sec. 913, 124 Stat. 1376 (2010).

* * * * *

Section 240.17ad-7 is also issued under 15 U.S.C. 78b, 78q, and 78q-1.

* * * * *

2. Amend § 240.17a-4 by adding and reserving paragraph (e)(13), and adding paragraph (e)(14) to read as follows:

§ 240.17a-4 Records to be preserved by certain exchange members, brokers and dealers.

* * * * *

(e) * * *

(13) [Reserved]

(14)(i) The written policies and procedures required to be adopted and implemented pursuant to § 248.30(a)(1) of this chapter until three years after the termination of the use of the policies and procedures;

(ii) The written documentation of any detected unauthorized access to or use of customer information, as well as any response to, and recovery from such unauthorized access to or use of customer information required by § 248.30(a)(3) of this chapter for three years from the date when the records were made;

(iii) The written documentation of any investigation and determination made regarding whether notification is required pursuant to § 248.30(a)(4) of this chapter, including the basis for any determination made, any written documentation from the United States Attorney General related to a delay in notice, as well as a copy of any notice transmitted following such determination, for three years from the date when the records were made;